

Cloud Security

Chapter 11 | Cloud Computing: Concepts and Technologies

Sunilkumar S. Manvi Gopal Krishna Shyam

CRC Press, 2021

Slides derived from Chapter 11, pp. 205–227.

Outline

11.1 Data Security

11.2 Encryption Techniques in Cloud

11.3 Infrastructure Security

11.4 PaaS Application Security

11.5 SaaS Application Security

11.6 Securing Virtual Servers

11.7 Cloud Security Controls

Learning objectives

Assess data security in the Cloud • describe security management in the Cloud • compare and contrast IaaS, PaaS and SaaS security in Cloud deployments.

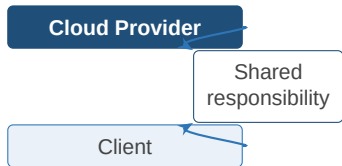
What Cloud Security Covers

A sub-domain of **computer security**, **network security** and, more broadly, **data security**.

Applies across all...

- **Service models:** SaaS, PaaS, IaaS
- **Deployment models:** private, hybrid, public, community

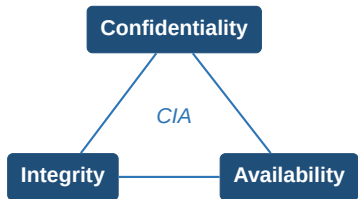
Security concerns split into two categories: those faced by **providers** and those faced by **clients**.



Provider: services are secure; customer data and applications are protected.

Client: supports those measures, e.g. strong passwords.

Preliminaries: Confidentiality, Integrity, Availability



- **Confidentiality:** prevention of intentional or unintentional unauthorized disclosure of contents.
- **Integrity:** assurance that the message sent is the message received, and was not changed on the way.
- **Availability:** the components that create reliability and stability, so authorized clients reach the system when needed.

Why it changes in the Cloud

A large part of network, system, applications and information moves under third-party control, creating islands of **virtual perimeters** plus a security model shared between the client and the **CSP**.

11.1 Data Security: Data-in-Transit

Data-in-transit identifies **data that requires encryption** while moving from one device to another.

Public networks	Private networks	Local devices
Transfer over the Internet, e.g. a mobile app calling a banking service. Typically encrypted using protocols such as HTTP.	Transfer over a secured LAN. <i>Defense in depth:</i> do not trust that a network is properly secured. Apply the same encryption as on public networks.	Transfer between computers, storage devices and peripherals. The medium itself can intercept, e.g. a USB cord that records or transmits.

11.1 Data-in-Transit: Categories and Primary Risk

Two categories

1. Information flowing over a **public or untrusted** network, such as the Internet.
2. Data flowing within the confines of a **private** network, such as a corporate or enterprise LAN.

Primary risk

Not using a **vetted encryption algorithm**. Obvious to security professionals, but often not understood by others using a public Cloud, whether IaaS, PaaS or SaaS.

Beyond the data itself: metadata

What metadata does the provider hold about the data, how is it secured, and what access does the customer have to it? As data volume with a provider grows, **so does the value of that metadata**.

11.1 Significant Security Concerns in the Cloud

Cloud computing spans networks, databases, operating systems, virtualization, resource scheduling, transaction management, load balancing, concurrency control and memory management.

- **Data transmission** over a communication medium
- **Virtualization security** of the virtual environment
- **Network security** of assets and traffic
- **Data integrity**: what may be shared with third parties
- **Data privacy**: accuracy and consistency of stored data
- **Data location**: logical pools across many servers
- **Data availability**: from normal through “disastrous” situations

Two examples of what must be secured: the network interconnecting systems in a Cloud, and the mapping of virtual machines onto physical machines.

11.2 Encryption Techniques in Cloud

Cloud encryption transforms a Cloud service customer's data into **ciphertext** before it is placed on a storage Cloud.

ABE	FHE	SE
Attribute-based encryption. Public-key encryption where the secret key and the ciphertext depend on <i>attributes</i> . Decryption works only if the attribute sets match.	Fully homomorphic encryption. Allows computation on encrypted data, including sum and product, <i>without decryption</i> .	Searchable encryption. Secure search over encrypted data. Split into secret-key (symmetric) and public-key SE.

To improve search efficiency, symmetric-key SE generally builds *keyword indexes* to answer user queries.

11.2 Attribute-Based Encryption: Two Policies

CP-ABE | Ciphertext-policy

The **encryptor** controls the access strategy.

Main idea: focused on the design of the **access structure**.

KP-ABE | Key-policy

Attribute sets describe the encrypted texts.

Private keys are associated with the specified policy that users will have.



11.2.1 Decentralized KP-ABE: Five Sub-modules

In a **decentralized** scheme there is no fixed number of attribute authorities. Any authority can join or leave **without rebooting the system**.



- **Global setup:** security parameter in, system parameters out, for any authority that joins.
- **Authority setup:** each authority generates public and private keys for the attributes it maintains.
- **Key issuing:** user and authority interact through an *anonymous key issuing protocol*; the authority returns decryption credentials.
- **Encryption:** takes an attribute set plus the data, outputs the ciphertext.
- **Decryption:** succeeds *if and only if* the user attributes satisfy the access structure.

11.2.2 Security Game: The Selective ID Model

ABE schemes are proven secure against the **selective identity (ID) model**, represented as a game between an **adversary** and a **challenger**.

1. **Secret key queries.** Any number of queries, but each user must have at least one *non-corrupted* authority.
2. **Challenge.** Adversary sends m_0 and m_1 in plain domain; challenger encrypts one at random.
3. **More secret key queries**, subject to the same requirement.
4. **Guess.** Adversary names the encrypted message.

Success condition

The adversary succeeds if it guesses correctly with probability

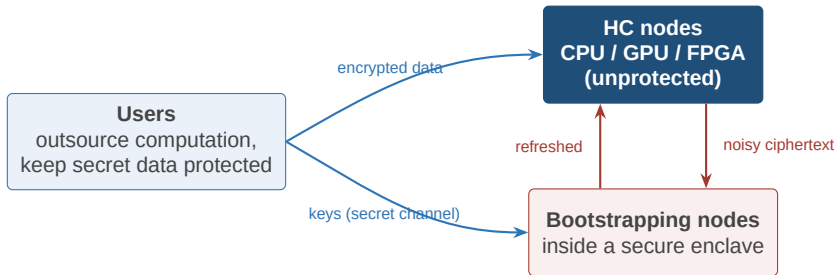
$$\frac{1}{2} + \epsilon$$

where ϵ is a **non-negligible function**.

If the adversary cannot decrypt with non-negligible advantage, the scheme is secure against the selective ID model.

11.2.3 Fully Homomorphic Encryption: Participants

Multiple parties play three key roles in the secure computation.



1. Users verify the Cloud configuration through **remote attestation** and establish a shared secret key with the bootstrapping nodes.
2. Users provision encryption parameters and keys over that secret channel.
3. Data encrypted under the homomorphic secret key goes to the **HC nodes**.

11.2.3 FHE: Bootstrapping and Why It Matters

Bootstrapping removes noise

The intermediate ciphertext travels from the HC nodes to the bootstrapping nodes. Running inside a **secure enclave**, they **decrypt**, then **re-encrypt** with the secret key and return the refreshed ciphertext. This removes the noise and enables further homomorphic computation.

When the whole computation finishes, the ciphertext returns to the users, who decrypt it to retrieve the result.

Use case

Privacy-preserving **outsourced storage and computation**: data is encrypted and outsourced to commercial Clouds for processing, all while encrypted.

Regulated industries

In healthcare, **predictive analytics** is hard to apply because of medical data privacy. If the provider operates on encrypted data instead, those concerns are diminished.

11.2.4 Searchable Encryption

Identify **encrypted content** from a segment of information about it, **without exposing the content itself**.

- Owner encrypts data with a **private key**.
- Keywords are shared encrypted under the search provider's public key, or a shared secret key.
- On a query, the provider opens the keyword envelope and matches, then connects owner and requester, who negotiate access **without the provider present**.

Example: routing urgent mail

Alice wants all mail marked “Urgent” forwarded to John while she is away. Bob encrypts an email under Alice's public key, so the gateway cannot tell whether to route it. John extracts the keyword *urgent*, applies **Public Key Encryption with keyword search**, and sends the result to the gateway, which can now decrypt the keyword list and route the message.

11.2.5 Web Processing Service (WPS) on the Cloud

The **OGC** WPS defines a standardized interface so geoprocessing services can be delivered over the Internet (OGC 2007). A WPS can be deployed in **any of the three service models**.

IaaS

Full control over resources, but virtualization happens at a low level, so the user must address many security risks. Makes sense when an organisation deploys a *variety* of WPSs and can staff the administration.

PaaS

Higher level of abstraction, so the platform handles some scalability challenges. Input data may be embedded or referenced as a web resource. **But:** WPS source code cannot create temporary files; such data must go to Cloud database tables.

- Compute-intensive WPS (climate modelling) benefits from **resource scalability**; a suddenly popular WPS benefits from **user scalability**. OGC's WFS benefits from request scalability.
- **GAE** provides single sign-on for first-time registration: a generated password is sent to the user's phone and used only once.
- All Clouds allow **SSL**. SSL encrypts network communication; data encryption comes from programming libraries and DBMSs.

11.3 Infrastructure Security

Information security (InfoSec) prevents unauthorized access, use, disclosure, disruption, modification, inspection, recording or destruction of information, in *any* form.

Primary focus

Balanced protection of the **CIA triad**, with efficient policy implementation, without hampering organization productivity. Achieved through a multi-step **risk management process**: assets, threat sources, vulnerabilities, potential impacts, possible controls, then assessment of the plan.

To understand the threats, understand communications security:

- Communications and network security for voice, data, multimedia and facsimile, across local area, wide area and remote access networks.
- Internet, intranet and extranet in terms of firewalls, routers, gateways and various protocols.

11.3.1 The Network Level: Private Cloud $\approx$ Secure Extranet

With **private Clouds** there are **no new attacks, vulnerabilities or changes in risk** specific to the topology.

The IT architecture may change, but the network topology probably will not change significantly. If a private extranet already exists, the topology for a private Cloud is likely already in place, and today's security tools operate the same way.

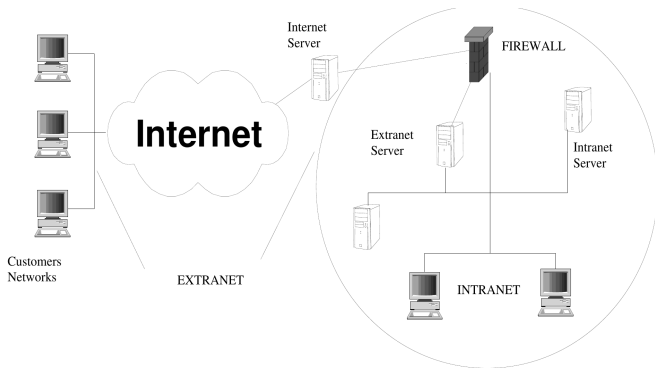


Figure 11.1: Similarities between a secure extranet and a private Cloud

11.3.1 Public Cloud: Three Significant Risk Factors

1. **Confidentiality and integrity of data-in-transit** to and from the public Cloud provider. Resources once confined to a private network are now exposed. HTTPS would have mitigated the integrity risk; users on HTTP faced data being altered without their knowledge.
2. **Proper access control** (authentication, authorization, auditing) for whatever resources are used at the provider. The ability to audit the provider's network, let alone monitor it in real time, is probably non-existent.
3. **Availability of the Internet-facing resources** in use or assigned by the provider. Reliance on network security has increased because more data and more personnel depend on externally hosted devices.

Misconfiguration is still a live risk

A study presented to **NANOG** in February 2006 found several hundred such misconfigurations per month. In February 2008 Pakistan Telecom announced a dummy route for YouTube to its partner PCCW to block the site domestically. **YouTube was globally unavailable for two hours.**

11.3.2 Trust Zones (TZ) Scheme

TZ = network segmentation + identity and access management (IAM) controls, defining physical, logical or virtual **boundaries** around network resources. Implemented with physical devices, virtual firewall and switching applications, or both.

Threat model: the CSP insider

CSP personnel with **physical access** to the datacenter can breach controls by direct access to physical machines. The large number of machines complicates the task, so the attacker must first locate the hardware hosting the target data.



Narrowing signals: security groups, open ports, IAM data, tenant naming conventions, relative memory / disk / CPU / IO sizing. **Defence:** segmented or compartmentalized datacenters, and keeping physical and logical maps separate, complicate the task.

11.4 PaaS Application Security

PaaS vendors fall into two categories: **software vendors** (Bungee, Etelos, GigaSpaces, Eucalyptus) and **CSPs** (Google App Engine, Force.com, Microsoft Azure, Intuit QuickBase).

Who secures what	Practical guidance
PaaS CSPs secure the platform software stack, including the runtime engine that runs customer applications. PaaS applications may use third-party applications, components or web services, so the third-party provider may be responsible for securing those.	Given the nascent stage of PaaS deployment, organizations evaluating PaaS software should perform a risk assessment and apply the same software security standard as for any enterprise software. Customers should understand their application's dependency on all services and assess third-party risk.

CSPs have been reluctant to share platform security information, arguing it would help hackers. Enterprise customers should demand **transparency**.

11.4 PaaS: Access Control, Hardening, SSO

Access control management

Covers users *and* privileged system administrators.
Address: entitlement assignment, assignment based on job function, authentication method and strength, auditing and reporting.

Hardening the host OS

Host OS vulnerabilities **flow upward** into the VM OS.
A compromise of the host OS gives access to *all* services on *all* VMs.

- Strong passwords, changed often
- Disable unneeded services, especially networked
- Require full authentication
- Firewall the host individually
- Patch regularly, tested off production

Single Sign-On (SSO)

One ID and password per work session, then automatic logon to all required applications.
Passwords must never be stored or transmitted in the clear.

Advantages: stronger passwords, easier administration, less time to access resources.

Major disadvantage: once past the initial logon, users can **freely roam** network resources without restriction.

Example: logging in to Gmail also grants YouTube, Google Drive and Google Photos.

11.5 SaaS Application Security

The provider manages the **entire suite** of applications, so SaaS providers are largely responsible for securing the applications and components they offer. Customers usually handle **operational security**, including user and access management as supported by the provider.

What to request from a prospective provider

Design, architecture, development, black- and white-box application security testing, and release management.

Where fine-grained control breaks down

Google Apps lets end users assign read and write privileges, but privilege management may not be fine-grained enough for an organization's access control standard. Embedded images in **Google Docs** are not protected the same way the document is: once shared, the other person can still view those images **even after sharing stops**.

11.5.1 FHE Scheme for SaaS Security: Worked Example

Unlike **partially** homomorphic encryption (some operations only), fully homomorphic encryption supports **arbitrary computation** on ciphertexts. A program never decrypts its inputs, so an **untrusted party** can run it without seeing inputs or internal state.

Business B and its very important data set (VIDS)

1. VIDS consists of the numbers **5** and **10**. To encrypt, Business B multiplies each element by 2, giving **10** and **20**.
2. The encrypted set goes to the Cloud for safe storage. Months later the government requests the sum of VIDS elements.
3. Business B asks the Cloud provider, which only has the encrypted set, to compute $10 + 20$ and returns **30**.
4. Business B decrypts the reply and gives the government the decrypted answer, **15**.

11.5.1 Access Control in SaaS

Network access control: diminishing

Users reach Cloud services from any Internet-connected host. Traditional network controls protect resources using **host-based attributes**, which are usually inadequate, not unique across users, and can cause inaccurate accounting.

In the Cloud it appears as **Cloud firewall policies** at ingress and egress points, using standard TCP/IP parameters: source IP, source port, destination IP, destination port.

User access control: emphasized

Binds a user's **identity** to Cloud resources. Supports fine granular access control, user accounting, compliance and data protection.

Key controls: **strong authentication, SSO, privilege management, logging and monitoring.**

ISO/IEC 27002 defines six access control objectives covering end user, privileged user, network, application and information access control.

Customers hosting on IaaS should monitor the health of *both* the hosted application and the virtual server instances.

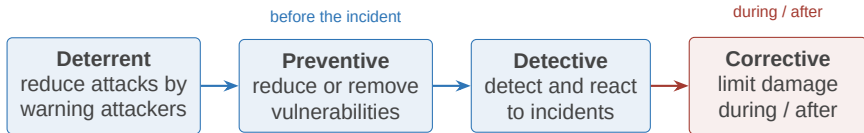
11.6 Securing Virtual Servers

Easy **self-provisioning** on IaaS creates the risk that insecure virtual servers get created. Secure-by-default configuration must follow or exceed available industry baselines.

- **Use a secure-by-default configuration.** Build custom VM images with only the capabilities and services the application stack needs. This limits the attack surface *and* reduces patching.
- **Track the inventory of VM images and OS versions.** Provider images must undergo the same verification and hardening as internal hosts. Best alternative: supply your own conforming image.
- **Safeguard the private keys** for host access. Isolate decryption keys from the Cloud holding the data, unless they are needed there.
- **No authentication credentials in virtualized images**, except a key to decrypt the filesystem key. No password-based shell access; passwords are mandatory for `sudo` or role-based access.
- **Run a host firewall**, opening only the minimum ports. Turn off unused services such as FTP, print, network file and database services.
- **Enable system auditing and event logging** to a dedicated, isolated log server with higher protection.

11.7 Cloud Security Controls

Security architecture is effective only if the correct defensive implementations are in place. Controls safeguard weaknesses and reduce the effect of an attack.



- **Deterrent:** like a warning sign, informs attackers of adverse consequences.
- **Preventive:** strong authentication makes unauthorized access less likely and positive identification more likely.
- **Detective:** system and network monitoring, intrusion detection and prevention; signals the preventive or corrective controls.
- **Corrective:** restoring system backups to rebuild a compromised system.

Key Takeaways

- Cloud security is a **shared responsibility**: providers secure the service, clients support those measures.
- The **CIA triad** still frames the problem, but much of the stack now sits under third-party control.
- For data-in-transit the primary risk is **not using a vetted encryption algorithm**, in any service model.
- **ABE, FHE and SE** answer different needs: attribute-driven access, computation on ciphertext, secure search.
- A private Cloud resembles a **secure extranet**; public Clouds add exposure, weak auditability and external availability risk.
- Security management works through **deterrent, preventive, detective and corrective** controls.

From the chapter summary

Organizations relying solely on a vendor's built-in security expose themselves to unnecessary risk. Credentials and secrets proliferate across Cloud environments, and **many are never secured**. If compromised, they give attackers lateral access across networks, data and applications.

Questions & Discussion

Chapter 11 • Cloud Security

Manvi & Shyam, *Cloud Computing: Concepts and Technologies*, CRC Press, 2021, pp.
205–227